

INFORMATION SECURITY POLICY

Florence Nkosi, CISA|CEH

INFORMATION SECURITY POLICY

- An information security policy (ISP) is a set of rules that guide individuals who work with IT assets.
- Information security policy refers to *clear*, *comprehensive*, and *well-defined* plans, rules, and practices that regulate **access** to an organization's system and the information included in it.
- Good policy protects not only information and **systems**, but also individual employees and the organization as a whole.
- Your company can create an information security policy to ensure employees and other users follow security protocols and procedures.

The Importance of an Information Security Policy

- Creating an effective security policy and taking steps to ensure compliance is a critical step to prevent and mitigate security breaches that may happen in an organization.
- To make your security policy truly effective, update it in response to changes in your company, new threats, conclusions drawn from previous breaches, and other changes to your security posture.
- Make your information security policy practical and enforceable. It should have an exception system in place to accommodate requirements and urgencies that arise from different parts of the organization.

The Importance of an Information Security Policy

- The goal of security policies is to address security threats and implement strategies to mitigate IT security vulnerabilities, as well as defining how to recover when a network intrusion and security breaches occurs.
- Furthermore, the policies provide guidelines to employees on what to do and what not to do.
- They also define who gets access to what, and what the consequences are for not following the rules.

Elements of an Information Security Policy

- A security policy can be as broad as you want it to be from everything related to IT security and the security of related physical assets, but enforceable in its full scope.
- The IT Security Policy is a living document that is continually updated to adapt with evolving business and IT requirements.
- The following list offers some important considerations when developing an information security policy:
  1. Purpose
  2. Audience
  3. Information security objective
  4. Authority and access control policy
  5. Data classification
  6. Data support and operations
  7. Security awareness

1. Purpose

- Outline the purpose of your information security policy which could be to:
  - Create an organizational model for information security
  - Detect and preempt information security breaches caused by third-party vendors, misuse of networks, data, applications, computer systems and mobile devices.
  - Protect the organization's reputation
  - Uphold ethical, legal and regulatory requirements
  - Protect customer data and respond to inquiries and complaints about non-compliance of security requirements and data protection

2. Audience

- Define who the information security policy applies to and who it does not apply to.
- You may be tempted to say that third-party vendors are not included as part of your information security policy.
- This may not be a great idea. Third-party, fourth-party risk and vendor risk should be accounted for.
- Whether or not you have a legal or regulatory duty to protect your customer's data from third-party data breaches and data leaks isn't important.
- Customers may still blame your organization for breaches that were not in your total control and the reputational damage can be huge.

3. Information security objectives

- These are the goals management has agreed upon, as well as the strategies used to achieve them.
- In the end, information security is concerned with the CIA triad:
  - Confidentiality: data and information are protected from unauthorized access
  - Integrity: Data is intact, complete and accurate
  - Availability: IT systems are available when needed

4. Authority and access control policy

- This part is about deciding who has the authority to decide what data can be shared and what can't.
- An access control policy can help outline the level of authority over data and IT systems for every level of your organization.
- It should outline how to handle sensitive data, who is responsible for security controls, what access control is in place and what security standards are acceptable.
- It may also include a network security policy that outlines who can have access to company networks and servers, as well as what authentication requirements are needed including strong password requirements, biometrics, ID cards and access tokens

5. Data classification

- An information security policy must classify data into categories.
- A good way to classify the data is into five levels that dictate an increasing need for protection:
  - **Level 1:** Public information
  - **Level 2:** Information your organization has chosen to keep confidential but disclosure would not cause material harm
  - **Level 3:** Information has a risk of material harm to individuals or your organization if disclosed
  - **Level 4:** Information has a high risk of causing serious harm to individuals or your organization if disclosed
  - **Level 5:** Information will cause severe harm to individuals or your organization if disclosed
- In this classification, levels 2-5 would be classified as confidential information and would need some form of protection.

6. Data support and operations

- Once data has been classified, you need to outline how data at each level will be handled.
- There are generally three components to this part of your information security policy:
  - Data protection regulations: Organizations that store personally identifiable information (PII) or sensitive data must be protected according to organizational standards, best practices, industry compliance standards and regulation
  - Data backup requirements: Outlines how data is backed up, what level of encryption is used and what third-party service providers are used
  - Movement of data: Outlines how data is communicated. Data that is deemed classified in the above data classification should be securely communicated with encryption and not transmitted across public networks to avoid man-in-the-middle attacks

7. Security awareness training

- A perfect information security policy that no one follows is no better than having no policy at all. You need your staff to understand what is required of them.
- Training should be conducted to inform employees of security requirements, including data protection, data classification, access control and general cyber threats.
- Security training should include:
  - Social engineering: Teach your employees about phishing, spear phishing and other common social engineering cyber attacks
  - Clean desk policy: Laptops should be taken home and documents shouldn't be left on desks at the end of the work day
  - Acceptable usage: What can employees use their work devices and Internet for and what is restricted?

How to Develop Policy

- An Information security policy must be based on the results of a risk assessment
- Findings from a risk assessment provide policy-makers with an accurate picture of the security needs specific to their organization.
- This information is imperative because proper policy development requires decision-makers to:
  - Identify sensitive information and critical systems
  - Incorporate local, state, and federal laws, as well as relevant ethical standards
  - Define institutional security goals and objectives
  - Set a course for accomplishing those goals and objectives
  - Ensure that necessary mechanisms for accomplishing the goals and objectives are in place

Security Configuration Management

- Fundamentally, secure configuration management refers to the set of security policies and procedures applied on systems, applications, and network devices.
- Security configuration management involves continually detecting configuration drifts and misconfigurations across various components in your endpoints, and bringing them back into alignment.
- The goal of SCM is to reduce security risks by ensuring that systems are properly configured — hardened — to meet internal and/or regulatory security and compliance standards.
- Can use software's like **Vulnerability Manager Plus, Solar Winds Server Configuration Monitor**

Security configuration management

- Typical security configuration management (SCM) combines network monitoring and endpoint protection methodologies to compare monitored systems against an approved configuration baseline.
- Differences from this baseline, known as test failures, can often be corrected with little to no human intervention

Tips to Ensure Secure Configuration Management

1. Avoid configuration errors by analyzing configuration changes before they are applied.
2. Check configurations against corporate polices and external standards like Payment card Industry(PCI), Health Insurance Portability and Accountability Act (HIPAA), and Information Technology Infrastructure Library (ITIL).
3. Reduce room for manual errors by standardizing and consolidating management of multivendor devices. This helps simplify deployment of standard configurations on multiple devices.
4. Follow a change approval process and implement user roles to restrict access to making configuration changes.
5. Establish and maintain baselines for devices in the network—critical devices most importantly.
6. Know what devices are running in your network and remove unused devices

Configuration Management

- Network configuration management involves collecting different information about hardware devices, software programs and other elements of the network in order to support administration and troubleshooting.
- All sorts of networks, including local area networks, wireless networks and virtual networks all need elements of maintenance, modification, repair and general monitoring.

Configuration change management

- At its simplest, configuration change management simply means keeping track of the changes you make and evaluating proposed changes for their effect before actually implementing them.
- In practice, change management involves some fairly well-defined tasks:
  - Maintaining documentation that describes the current configuration of all network devices
  - Maintaining documentation that describes the purpose and details of any changes
  - Maintaining an archive of older configurations so that they can be used in an emergency
  - Implementing policies that control the rate of change
  - Implementing policies that control who may perform changes
- Configuration management will control changes and test documentation throughout the operational life cycle of each technology component and software
- Configuration management is essential to disaster recovery. It is impossible to recover to a last known good configuration if there is no documentation or if the documentation is incorrect

Network configuration management tools

- Network configuration management tools help administrators to adapt more quickly to emergencies or to make maintenance and repair processes more efficient.
- Develop an inventory of all authorized and unauthorized hardware, software and other devices. Using that information, IT security personnel can track and correct all authorized devices and software.
- They can also deny access to unauthorized and unmanaged products as well as prevent unapproved software from installing or executing on network devices.

Features of a Network Configuration Management System

1. Network device discovery
2. Configuration backup
3. Configuration change management
4. Executing complex network operations
5. Network compliance to industry standards

Features of a Network Configuration Management System

- 1. **Network device discovery**
  - Discovering your device and adding it on to the inventory is the first step in network configuration management. It is important to keep records of your network devices and their hardware properties.
  - Besides improving the network admin's visibility into the network devices, an informative inventory will help the admin conduct regular audits.
  - The inventory gives a detailed view into the device specifics such as the serial numbers, interface details, port configurations and hardware specifics of the device which will all prove useful while compiling audit reports.

2. Configuration backup

- A network operator must always be ready for a network mishap and the most fundamental element in becoming disaster-ready is taking network backups.
- A faulty change or update can cause problems like a network outage or a security breach. Any such events can immediately be dealt with by overwriting the faulty configuration with a trusted version from the backup.

Features of a Network Configuration Management System

- **3. Configuration change management**
  - It is recommended that you keep a record of your users to facilitate easier identification of configuration changes.
  - In a network that houses multiple operators, it is crucial to avoid any unauthorized change that might bring about an unfavorable output.
  - While these only cut down the chances of something going wrong on the network, they don't entirely eliminate the chances of it happening.
  - This is where the configuration backups come into a play. You can readily upload a trusted version of the configuration and restore the device and ensure business continuity.

Features of a Network Configuration Management System

- **4. Executing complex network operations**
  - Network Configuration Management includes the execution of many network operations and sometimes these can also be automated.
  - For instance, if you need to change the password of all cisco routers on a network, applying the change to every device individually would be a tedious process.
  - This is where configuration templates that are commonly called 'Configlets' come into play.
  - You can centrally execute this operation to all the devices using configlets.
  - They also come with the added advantage of scheduling, which does not require the user to be around while the operation is being executed.

Features of a Network Configuration Management System

- **5. Network compliance to industry standards**
  - There are some industry standards to which your network devices must comply to. This is to ensure that your data is secure and to keep your business away from the risk of disreputation.
  - PCI Compliance:
    - This applies to any company that accepts card payments, stores, processes and transmits cardholder data.
    - Condition: There is a condition in the PCI Compliance Policy that requires the password of all devices to be reset every 6 months.
    - Action Required: The network admin has to check if the password has been changed on time.
  - Cisco IOS Policy:
    - This policy applies to all network devices that run on Cisco Internet Operating System.
    - Condition: A rule in the Cisco IOS Policy requires to check if there is a public community in the configuration.
    - Action Required: The network admin has to remove public community from the configuration.

Network configuration tools

- Network configuration management tools help administrators to adapt more quickly to emergencies or to make maintenance and repair processes more efficient.
- The role of configuration management is to maintain systems in a desired state.
- Traditionally, this was handled manually or with custom scripting by system administrators.
- Automation is the use of software to perform tasks, such as configuration management, in order to reduce cost, complexity, and errors.
- Some configuration management tools track configuration data on a daily basis to spot any changes in configuration files, which could reveal cyber threats and potential failures. Network configuration tools can be used to create bulk changes.

Network configuration tools

- Configuration management tool, is used to store the current state of your systems and help you to maintain that state. Configuration management tools make changes and deployments faster, remove the potential for human error, while making system management predictable and scalable.
- They also help you to keep track of the state of your resources, and keep you from repeating tasks, like installing the same package twice.
- Improve system recovery after a critical event with automated configuration management. If a server goes down for an unknown reason, you can deploy a new one quickly and have a record of any changes or updates that occurred so you can identify the source of the problem.
- Your configuration management tools can also help you to run an audit of your system so you can more quickly identify where the problem is coming from.

Network Configuration Manager

- Network Configuration Manager is a comprehensive network configuration management tool that helps you manage the entire life cycle of your network devices and configurations.
- It provides you solutions for network configuration, change and compliance management.
- The tool also assists you with crucial network operations like automating complex network operations, scheduling backups, tracking user activity, generating detailed reports and a lot more.

Benefits of using Network Configuration Manager

1. Built-in multi-vendor device configurations.
2. Take automated backups of your configuration files.
3. Encrypt and store configuration files.
4. Track configuration changes in real-time.
5. Record a history of configuration changes.
6. Recover from network disasters instantaneously.
7. Enhanced network security by preventing unauthorized configuration changes and notifying the admin.
8. Reduce configuration errors by regulating changes with change management.
9. Automate both simple and complex network operations.
10. Ensure device configuration compliance to industry standards.
11. Save time spent on repetitive tasks.
12. Roll-back mechanism when configuration changes are unsatisfactory.
13. Generate insightful reports on changes, compliance, inventory and other vital network parameters.

Audit Trails

- Audit trails are the manual or electronic records that chronologically catalog events or procedures to provide support documentation and history that is used to authenticate security and operational actions, or mitigate challenges.
- An audit trail is a register of every action, event, or activity a user or a system did with your data
- Audit trail records will contain details that include date, time, and user information associated with the transaction.
- An audit trail is also referred to as an audit log

What are audit trails used for

1. Information security – identify that something wrong has happened. This happens only in case you are using a secure way to store and track activities related to information security
2. Regulatory compliance – keyword "Secure": to ensure your logs comply with most of the standards and regulations, you need to have tamper-evident, secure audit logs in place. More insight you can also read below.
3. Digital forensics – find out who did what and when and be able to prove it. This is especially crucial where lawsuits are involved.
4. Data integrity – when using the right technology the audit trail can allow you to reconstruct the data that was modified and the time it was modified, so that you know which backup to use, relying on the data provided in it.
5. Business Analysis – logs, when generated and collected properly, contain all the necessary data for business processes because most business processes take place or are reflected in information systems nowadays.
6. Fraud & Anomaly Detection – when using the appropriate secure audit trail solution, that captures all business-related activities from all systems, any organization can make fraud detection easy in real-time.

Types of Audit Trail Activities and Contents

- An audit trail provides basic information to backtrack through the entire trail of events to its origin, usually the original creation of the record.
- This may include user activities, access to data, login attempts, administrator activities, or automated system activities.
- Audit records contain elements defined by the company which include:
  - What the event was
  - What user, system, or application launched the event (this information may include IP address and device type)
  - The date and time the event occurred

Benefits of Audit Trails

- Automated auditing trails do this work by holding individual users accountable for their interactions with a record, reconstructing the events that happen in its life, detecting intrusions and suspicious behavior, and identifying system implementation issues and system/operator errors.

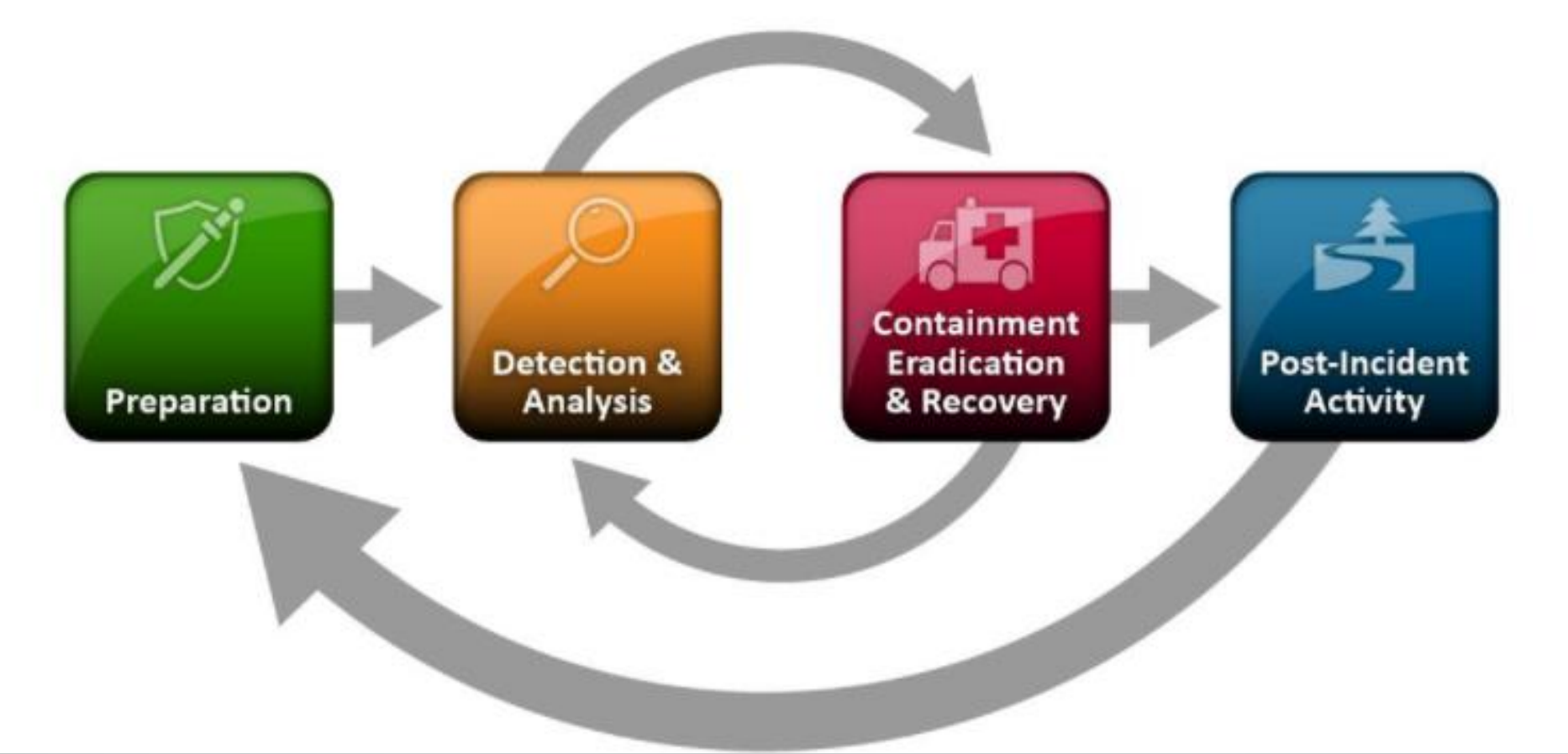
Incident response

- An incident is A single or a series of unwanted or unexpected computer security events that have a significant probability of compromising business operations and threatening cybersecurity. - **ISO Definition**
- Incidents can be: Compromised server, virus infection, information leakage, DDoS attacks e.t.c
- In their book Practical UNIX Security, Simson Garfinkel and Gene Spafford provide two excellent, overriding rules for incident response.
    - Rule 1: Don't Panic!
    - Rule 2: Document!

Incident response process

- An effective information security incident response process includes 4 basic stages:
- Preparation; detection and analysis; containment, eradication, and recovery; and post-incident review.

Incident response process



Incident response process

Preparation

- An institution's information security incident response management program is evidenced by policies and incident handling procedures.
- These documents should be clear and concise, describing the steps members (from end user to incident response staff to leadership) must take in response to an actual or suspected incident.
- During this **preparation** stage, the institution identifies the resources needed for incident response capabilities, ensures that it has individuals who are properly trained and ready to respond to information security incidents, and develops and communicates the formal detection and reporting processes

Incident response process

Detection and Analysis

- Designing an effective mean to detect information security incidents is also essential. Information security incidents can be reported by end users, and they can also be detected (and reported) via trained IT personnel.
- This is why it is so important that all campus personnel be trained on the proper way to report a suspected information security incident.
- In addition to reporting, technical controls must be implemented for the automated detection of security events, coupled with as near real-time reporting as possible, to investigate and initiate response activities.

Incident response process

Detection and Analysis(cont'd)

- In addition to detecting an incident (through a number of mechanisms), it is imperative that the information security incident be timely assessed to determine the types of information technology resources and institutional data potentially involved in the incident, and to understand the severity level of the incident (ranging from low to high severity).
- During this analysis, the operational incident response team will also try to understand the scope of the suspected incident.

Incident response process

Containment, Eradication, and Recovery

- It should be noted that most incident response steps don't happen sequentially, or with clear delineations between tasks.
- Once a suspected incident is confirmed, sometimes detection and analysis, and containment, eradication, and recovery activities may all happen at the same time or with a speed that suggests that they are happening at the same time.

Incident response process

- During this phase, operational incident response teams may do these types of containment activities:
  - Confine and mitigate the incident to prevent further disruption and/or spread to other systems or campuses.
  - Conduct any additional investigation and/or analysis, especially for incidents that may be of perceived higher severity.
  - Acquire, preserve, secure, and document evidence.
  - In coordination with IT and campus leadership, provide information regarding service disruption and the potential need to activate business continuity plans to the campus community.
- Incident response teams may do these types of eradication and response activities during this phase:
  - Identify and mitigate all vulnerabilities that were exploited in the incident.
  - Remove malware, inappropriate materials, or other components and securely configure affected systems appropriately.
  - Redeploy securely configured systems to an operational state, and confirm that the systems are functioning normally.

Incident response process

Post Incident Review

- The post incident review phase is critically important and oft overlooked. During this phase the operational incident response team, and campus and IT leadership come together after an information security incident is closed (or active incident response activities have concluded) to identify lessons learned and how to better handle future information security incidents.
- Activities in this stage may include:
  - Hold a "lessons learned" meeting to discuss how the incident response process worked and what went well (and what can be improved).
  - Review corrective actions put in place during the incident response process for continued applicability.
  - Document the incident response process for metrics and historical purposes.
  - Determine if there are any high-level issues that need to be elevated to IT or campus leadership for resolution (e.g., whether cyber liability insurance would be useful, or whether there are significant costs to reduce a particular vulnerability).

Incident response process

Post-Incident review

- During this phase, campuses may also update their information security incident response metrics.
- The purpose of incident response metrics is to help the institution understand the major causes and sources of information security incidents, to measure damage caused by incidents, and to observe trends in both.
- Metrics may include the total incidents handled, time spent on incidents, the number of different types of incidents, and the number of systems impacted. Some useful incident response metrics to measure over time include:
  - The number of detected, but unsuccessful intrusion attempts to compare against the number of detected and successful ones.
  - The damage/losses caused by incidents, to help develop plans for reducing outages and the staff hours spent responding to incidents.
  - Reductions in downtime of the network or critical systems.

Additional Measures: Protecting your Networks

Administer Regular Software Updates and Patch Management

- 27% of reported breaches were the result of unpatched vulnerabilities, Data from Tripwire, a security company, also indicates that unpatched vulnerabilities were also responsible for 34% of data breaches for European organizations.
- Updating and patching up software is crucial to preventing exploitation via any known vulnerabilities in applications developed in-house or through proprietary software.
- Be sure to install available security patches and updates for all your software within a targeted timeframe that's in line with the entire organization's risk management process.

Other Measures

- Validate the Security of Network Devices
- All efforts to secure your network will be in vain if there are security loopholes or bugs in your connected network devices.
- Always check How secure are the devices that have access to your network?
- There are a few key things to consider:
  - All network devices (servers, desktops, routers, etc.) should only be purchased from authorized resellers and well-reputed vendors.
  - Also be sure to configure devices securely to turn off unnecessary services, disable unassigned or unused ports, manage default settings, etc.
  - When updating your network equipment devices, make sure that patches are downloaded only from validated sources.

- **Train Your Users**
- The weakest part of network infrastructure is often the people who are using it. All users need to be trained on best practices and updated on a regular basis. While people may not Intentionally mean to cause problems, those who are not immersed in the information technology world may not understand how to deal with threats appropriately

- https://hub.iiconsortium.org/portal/IISF_Part3/5b6de83f266d89000f876803
- https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-128.pdf